5- Performer le scan l'outil va recuperer l'empreinte numérique des cibles et re cuperer des informations basiques dessus avec ces informations l'outil va enu merer les services et cibles et collecter plus d'informations dessus.

6- Evaluer et considerer les risks possibles : le scan peu avoir un impact sur les cibles (Ex surcharge du server) il est nécessaire de le prendre e compte

7- Interpreter les resultats du scan Si il y a des exploits publiques pour une vulnérabilité découverte il faut la prioriser. Il faut aussi à cette étape dé celer & et eloigner les faux positifs.

8- Créé un plan de remédiation et atténuation Le personnel IT et sécurité doi collaborer étroitement pour patcher et/ou attenuer l'impact des failles déte tées.

Les entreprises et organisations sont soumises à des normes de conformité en matie de sécurité numériques

HIPAA: loi sur la portabilité et sécurité en matière d'assurance maladie, utilisé pour protéger les données des patients

FISMA: loi fédéral sur la gestion de sécurité de l'information, ensemble de n rmes et directives utilisées pour protéger les operations et information gouvernement

ISO27001: norme mondiale pour gerer la sécurité de l'information (exiges de analyses externes et internes trimestrielles).

Il existe aussi des normes de pentesting (en dehors des reglementations ethico-lga les) en fonction du system informatique evalué qui permettent de definir des stan dards (PTES OSSTMM NIST OWASP).

- Le langage **OVAL** est un format de fichier texte (en XML) compatible avec les scanners de sécurité, qui automatise la recherche des failles de sécurité sur un ordina teur, c'est une simple liste de control lisible par les logiciels de sécurité:
  [1] le fichier indique au logiciel le chemin précis de l'element du system à audit (clé de registre windows*, fichier spécifique, version du logiciel. etc..)
  [2] le fichier précise (l'etat attendu) la valeur exacte que l'element doit avoir pour être sécurisé (Ex version superieur ou égale à 12.3.5)
  [3] le test, le scanner compare l'element reel de la machine avec l'état attendu, s le critique n'est pas respecté le scanner la déclare comme vulnérable.

* Une clé de registre Windows est une ligne de texte stockée dans une immense base de donnée appellé registre à l'intérieur de windows. Elle contient les reglages options et configurations de notre system d'exploitation et ses logiciels.

Les **CVE** ou Common Vulnérabilités and Exposures c'est une base de donnée pu blique mondiale qui attribue un identifiant unique (sous format CVE-ANNEE-NUMERO) à chaque failles de sécurité informatiques découvertes - sur des technologies un minimum connues et utilisées -
Une fiche CVE tel que disponible sur le site de la NVD se compose du numéro d'iden tification uniques, d'une description de la faille et d'un score de gravité CVSS noté de 1 à 10.

- Le scan de vulnérabilité (logiciel) n'exploite generalement pas les vulnérabilités se contente de les remontées une validation humaine est donc requise pour eloigner les faux positifs Les logiciels effectuent une serie de test dinamiques (pendant que le logi ciel s'exécute) et statiques (à l'arrêt)
  - Nessus Essentials version gratuite et limité du scanner officiel de Nessus (limité à 16 hotes
  - OpenVas scanner gratuit et open-source peu effectué scan reseau avec et sans authenti